MAERSK

NotPetya

07:00

WHY

WAS MAERSK TARGETED?

Collateral victim

Like hundreds of other companies, Maersk was a victim of a wiper attack (NotPetya), which targeted the software **MeDoc** used for filing tax in Ukraine.

Cyberwarfare

Geopolitical reasons, the attack was **state-sponsored.**

Critical Infrastructure

By 2017 Maersk operated out of 343 ports worldwide and managed 18% of the world's container shipping. With 90% of orders processed online, disrupting its IT systems meant paralyzing the international supply chain.

WHY

WAS THE ATTACK SUCCESSFUL?

Lack of Segmentation

The absence of network segmentation allowed the malware to spread across all servers worldwide, paralyzing the entire company. All 150 backup servers were infected simultaneously, leaving only one offline server in Ghana as a potential recovery option.

Permanent Data Loss

The attack permanently destroyed critical business data, including customer contacts, invoices, and quotes, which were actively used in daily operations. Locally stored information on infected PCs without backups was lost forever, making recovery impossible.

Outdated Systems

Although system upgrades were approved, they were never implemented because performance bonuses were incentivized on uptime rather than security, prioritizing availability over protection.

Overlooked Warnings

The vulnerabilities were underestimated. Despite the warnings, no follow-up actions were taken. The outdated Windows 2000 servers remained unpatched, and the warnings were ignored.

Communication Blackout

The attack disabled email and phone systems, making internal and external communication impossible during the crisis.

HOW HAS MAERSK HANDLED IT?

Containment

IT teams immediately began shutting down systems to prevent further spread.

Incident response

Maersk hired the consulting firm Deloitte along with smaller IT firms, such as Predica.

Crisis communication strategy

Finding alternative communication channels for activity coordination (Whatsapp)

Searching for solution

By chance, it was discovered that a copy of the database was still accessible in Ghana due to a blackout that had temporarily disconnected an office from the global network.

Transparency

Maersk's openness and transparency in communicating the emergency fostered trust among customers and vital support from them.

Continuity of operations

Maersk prioritized keeping shipping operations running, quickly restoring port activities while managing underlying processes manually on paper

Loyal clients compensation

To mitigate the impact, Maersk compensated affected customers (around $1 million each).

Lost clients

Customers dissatisfied with the disservice, started looking for alternative suppliers leading to financial losses for the company.

Brand Impact

A disaster of this scale had a profound impact on Maersk's brand reputation and public image, influencing both customer trust and financial relationships with banks.

Rapid Recovery Investment

Made investments in deploying 4,000 new servers, 45,000 new PCs, and 2,500 applications all within just 10 days to restore operations.

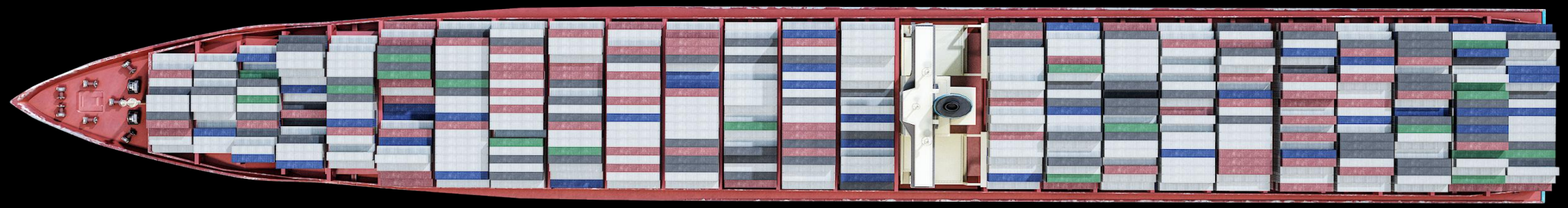
NotPetya took only 7 minutes to bring down entire networks

TIME OVER

HACKED

WHAT CAN BE DONE IN THE SHORT RUN?

- Establish **response procedures** to react swiftly to cyber threats.
- Develop a structured **communication plan** for rapid response during an attack.
- Identify **business-critical applications** and document them.
- Conduct a comprehensive **risk assessment** of **third parties** in high-risk regions (e.g., Ukraine, Iran) prone to cyberattacks



IN THE LONG RUN?

- **Investing in cybersecurity**
  Now a competitive advantage, essential for resilience of the GVC of the company.

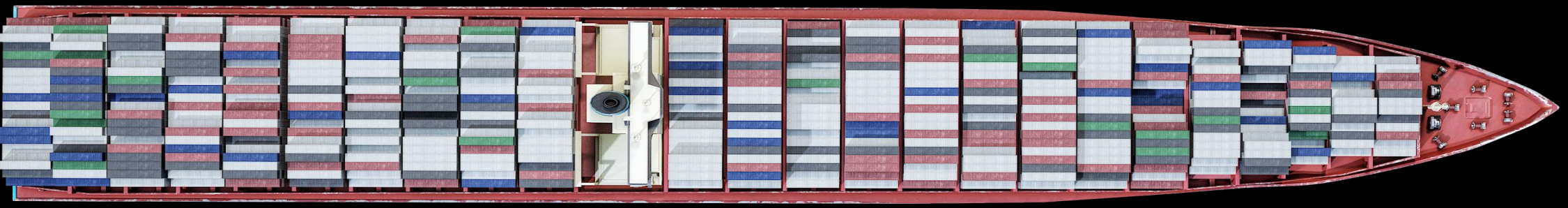
- **Building an Effective Cyber Incident Response Team**
  Ensuring swift, strategic, and coordinated actions to mitigate cyber threats.

- **Network segmentation**
  Zero-trust implementation, mitigate cyber risks by preventing widespread infections.

- **Privileged access management**
  Reducing infection risks by enforcing the least privilege principle.

- **Offline backup solutions**
  Air-gapped, cold storage, and distributed backup strategy (3-2-1-1-0) ensure data redundancy, security, and availability.

- **Active Directory restoration timeline (9 days currently)**
  Too long—setting a 24-hour target is critical.



- **Regular disaster recovery drills**
  Enhance preparedness for cyber incidents through practice.
- **AI-based intrusion detection systems**
  Improve threat detection and response.
- **Cybersecurity training**
  For all employees and for the supply chain players to build awareness and accountability.
- **Supply Risk Accountability**
  Differentiate between general suppliers and strategic based on criticality of products or services.
- **Supplier Access Control**
  Minimizing the risk of a compromised supplier becoming an attack vector.
- **Cybersecurity clauses in contracts**
  Ensuring compliance to security requirements.

QUESTIONS?

THANK YOU

BAMHAOUD CIRIELLO FORESTI SANTO SAVONA